

8-Week SOC Lab Implementation Plan

8-Week Implementation Plan — SOC-in-a-Box Lab (Wazuh SIEM/XDR)

This plan maps **both** rubrics — *Identify and Analyze Cyber Threats / Apply Vulnerability Assessment / Threat Intelligence / Risk Management / Security Monitoring* and *Network Topologies / Protocols & Architecture / Network Security Fundamentals / Access Control / Wireless Security / Network Security Tools / Monitor & Respond* — onto a single lab built around Wazuh, running across your two physical hosts and their VMs.

1. Lab Architecture

1.1 Physical + Virtual Inventory

Host	Hypervisor	VM	OS	Role	Rubric tie-in
Host A	VMware Workstation / VirtualBox	pfSense	pfSense CE	Router, firewall, IDS/IPS (Suricata pkg)	Network: Topologies, Protocols, Security Fundamentals, ACL
Host A	"	Wazuh All-in-One	Ubuntu Server 22.04	Wazuh Manager + Indexer + Dashboard (SIEM/XDR core)	Cyber: Security Monitoring & IR
Host A	"	OpenCTI	Ubuntu Server (Docker)	Threat Intel platform	Cyber: Threat Intelligence
Host A	"	Kali/Parrot	Kali or Parrot OS	Attacker/red-team box, dual-homed (flat LAN + protected segment)	Cyber: Threat Analysis, Vuln Assessment; Network: Tools
Host B	VMware Workstation / VirtualBox	Win-Target	Windows 10/11	Wazuh agent, victim endpoint	Cyber: Monitoring; Network: Access Control
Host B	"	Lin-Target	Ubuntu Desktop/Server	Wazuh agent, victim endpoint	same
Host B	"	Metasploitable2/DVWA	Linux	Deliberately vulnerable target, sits behind pfSense	Cyber: Vuln Assessment; Network: Security Fundamentals

1.2 Network Segments

Two subnets keep this achievable without a managed VLAN switch, while still giving you real routing/firewalling to document:

- **Subnet 1 — Management/Flat LAN — 192.168.1.0/24** All host NICs, Wazuh manager (192.168.1.10), OpenCTI (192.168.1.11), Win-Target (192.168.1.20), Lin-Target (192.168.1.21) — bridged to your home network so both physical hosts' VMs can freely reach the Wazuh manager.
- **Subnet 2 — Protected Segment — 10.10.10.0/24** A host-only internal switch on Host A, gatewayed by pfSense (10.10.10.1). Metasploitable/DVWA lives here (10.10.10.10). Kali is dual-homed: one NIC on 192.168.1.0/24, one NIC on 10.10.10.0/24, so all scans/attacks against the protected target must pass through pfSense — this is what gives you real firewall rules, ACLs, and IDS/IPS alerts to screenshot.

(If you later get access to a managed switch with VLAN tagging, this upgrades cleanly to true 802.1Q segmentation across both hosts — worth a sentence in your report as a "future improvement.")

1.3 Why this satisfies the rubric's architecture requirements

- **Topology:** LAN (both subnets) with a routed boundary = real topology to diagram, not just theory.

- **Subnetting:** two real subnets (192.168.1.0/24, 10.10.10.0/24) with a documented reason for the split (trust boundary).
- **OSI/TCP-IP mapping:** see Section 2 and the diagram — every device in the lab maps cleanly to a layer.
- **ACL / access control model:** pfSense LAN rules restrict which subnet-1 hosts can reach subnet-2; Wazuh dashboard role-based access gives you a second, application-layer access control model to document (e.g., RBAC vs. the network-layer ACL — good material for “1 access control model” and “1 user access level”).

2. OSI Layer Mapping (see diagram below)

Layer	Lab component	Why it belongs there
7 - Application	Wazuh dashboard, OpenCTI, SET phishing page, RDP/SSH to targets	These are the actual services being monitored/attacked/analyzed
6 - Presentation	TLS on Wazuh agent↔manager (port 1514/1515), HTTPS to dashboard	Encryption/encoding of the data in transit
5 - Session	Agent registration sessions, SSH sessions from Kali to targets	Persistent logical sessions Wazuh logs and correlates
4 - Transport	TCP 1514/1515 (Wazuh), TCP 443 (dashboard/OpenCTI), scan traffic (TCP/UDP via Nmap)	Where Suricata/pfSense state tables and Nmap operate
3 - Network	pfSense routing between 192.168.1.0/24 and 10.10.10.0/24, IP addressing scheme	Where your ACL/firewall rules and subnetting live
2 - Data Link	Virtual switches (vSwitch per host), MAC-level forwarding, WPA2/3 frame encryption if a wireless AP is added	Where switching and wireless link-layer security operate
1 - Physical	Host A NIC, Host B NIC, home router uplink (and Wi-Fi radio if used)	The literal cabling/RF/interfaces carrying everything above

Use this table as the caption/legend for the diagram; the diagram itself should show physical boxes on the left and the OSI stack annotated next to each hop.

3. Week-by-Week Plan

Week 1 — Environment Build + Network Topology (Network §1, §2)

Goal: Stand up hypervisors, pfSense, and base networking on both hosts. - Install hypervisor on both hosts; create the two virtual switches (bridged + host-only). - Deploy pfSense; configure WAN (bridged/NAT to home router) and LAN (10.10.10.1/24). - Confirm Host A and Host B VMs can all reach 192.168.1.0/24. - **Deliverable:** Topology diagram (LAN with the routed 10.10.10.0/24 segment), OSI/TCP-IP diagram for one device (e.g., Win-Target) showing encapsulation from app data down to frames, subnetting worksheet for both subnets.

Week 2 — Access Control & Firewall Baseline (Network §3, §4)

Goal: Implement ACLs and access control models before anything is “live.” - Write pfSense firewall rules: deny subnet-1 → subnet-2 by default, allow only Kali’s second NIC + specific ports. - Document the model as a **DAC** (rule owner controls who’s allowed) vs. Wazuh dashboard **RBAC** roles for a second access-control example. - Create at least one non-admin Wazuh dashboard user with a restricted role (satisfies “1 user access level”). - **Deliverable:** Firewall rule screenshot + explanation, ACL table, access-control-model writeup.

Week 3 — Wazuh SIEM/XDR Deployment + IDS/IPS (Network §3 continued; Cyber §5 begins)

Goal: Get the monitoring backbone running — this underpins every later week. - Install Wazuh agents on Win-Target, Lin-Target, Metasploitable, Kali. - Install Suricata on pfSense in IDS mode, then IPS (blocking) mode with one rule set enabled (e.g., ET Open). - Generate one detected event (e.g., a port scan) and capture the IDS alert, then re-run with IPS blocking to show a dropped/blocked event. - **Deliverable:** IDS config + 1 example detected event; IPS config; Wazuh agent enrollment evidence.

Week 4 — Vulnerability Assessment & Asset Discovery (Cyber §2)

Goal: Formal scanning documentation. - Run an **Nmap** scan against 10.10.10.0/24 from Kali (through pfSense) — document scan flags/config, findings, and CVSS-based classification of at least a few findings. - Run **OpenVAS** (or Nmap NSE vuln scripts if OpenVAS is too heavy for the hardware) against Metasploitable for a deeper vuln scan. - Run a separate **asset discovery scan** (e.g., `nmap -sn`) across both subnets, documenting discovered hosts/services and a basic network map. - **Deliverable:** Vuln scan report, asset discovery report, methodology + security-implication write-up.

Week 5 — Wireless Security + Network Security Tools (Network §5, §6)

Goal: Cover the two “tooling” line items. - If you have a spare router/AP: configure WPA2 or WPA3 on it and document the config, plus research/document a WIPS approach (even a software one, e.g., Kismet, if no dedicated WIPS hardware) to detect rogue APs. If no physical AP is available, document a proposed WPA3 + WIPS design for the lab’s “wireless segment” and justify the choices — say so explicitly in the report. - Capture Wireshark traffic during a Week 4 scan and analyze it (protocol breakdown, one interesting packet exchange explained). - Use a network penetration testing tool (Metasploit against Metasploitable, or Nikto against DVWA) and capture output. - **Deliverable:** Wireless config doc, Wireshark capture + analysis, pentest tool output.

Week 6 — Threat Intelligence (Cyber §3)

Goal: Stand up OpenCTI and connect it to real data. - Deploy OpenCTI via Docker on Host A. - Configure at least 2 connectors (e.g., MITRE ATT&CK connector + AlienVault OTX or Abuse.ch connector). - Pull/identify 2 real IoCs (hash, IP, or domain) related to a known campaign, document detection method for each (e.g., matched against Wazuh’s threat intel integration or manually checked against VirusTotal) and how each indicates a threat. - **Deliverable:** OpenCTI setup + connector screenshots, 2 IoC write-ups.

Week 7 — Cyber Threat Analysis (Cyber §1)

Goal: The “attacker’s-eye-view” deliverables. - Analyze a malware sample in a **sandboxed, isolated VM** using VirusTotal or ANY.RUN/Hybrid Analysis — document detections, behavioral indicators, potential impact. (Do this only against a known/safe sample set — never live malware outside isolation.) - Build 1 phishing template using SET on Kali/Parrot, target it at Win-Target inside the isolated lab only. - Pick one real APT campaign and map its TTPs to the MITRE ATT&CK framework. - **Deliverable:** Malware analysis report, phishing template + SET session evidence, APT-to-ATT&CK mapping.

Week 8 — Risk Management, Incident Response, Final Compile (Cyber §4, §5; Network §7)

Goal: Close the loop — turn scan/detection data into risk + IR artifacts, then assemble the final report. - From Week 4’s vuln scan, pick 2 critical risks; document treatment recommendations and mitigation steps. - Create 1 risk monitoring procedure (how you’d re-scan/track these risks going forward, e.g., a recurring OpenVAS schedule + Wazuh vulnerability-detection module). - Run one full incident scenario end-to-end (e.g., replay the Week 7 phishing/Week 4 exploit chain), classify it, document response steps taken and lessons learned, using Wazuh alerts + logs + screenshots as evidence — this also satisfies Network §7 (monitor and respond to a security event with logs/screenshots). - **Deliverable:** Risk register (2 critical risks), risk monitoring procedure, full incident response report, final compiled documentation package covering all 13 rubric line items.

4. Final Rubric Coverage Checklist

Rubric item	Week	Evidence
Cyber: Identify/Analyze Threats	7	Malware report, SET phishing template, APT/ATT&CK map
Cyber: Vulnerability Assessment	4	Nmap + OpenVAS reports, asset discovery scan
Cyber: Threat Intelligence	6	OpenCTI + 2 connectors, 2 IoCs
Cyber: Risk Management	8	Risk register, risk monitoring procedure
Cyber: Security Monitoring & IR	3, 8	Wazuh setup, detection use case, IR scenario
Network: Topologies	1	Topology diagram (LAN + routed segment)
Network: Protocols & Architecture	1	OSI/TCP-IP diagram, subnetting, secure architecture
Network: Security Fundamentals	3	Firewall rule, IDS config, IPS config +

		detected event
Network: Access Control	2	ACL, access control model, user access level
Network: Wireless Security	5	WPA2/3 config, WIPS approach
Network: Security Tools	5	Wireshark capture, vuln scanner report, pentest output
Network: Monitor & Respond	8	Incident report with logs/screenshots

Note: All offensive activity (scans, phishing template, malware analysis, exploitation) should stay entirely inside the isolated lab subnets described above — never point tools at the live 192.168.1.0/24 home network beyond the specific lab VMs, and never let malware samples touch a host with internet/host-only bridging enabled.